

Adatvédelmi Hatásvizsgálat (DPIA)

Leakd — Felhő Szinkronizáció (Pro)

Hivatkozás: GDPR (EU) 2016/679 35. cikk · Dokumentum verzió: 1.0 · Készült: 2026. május 19. ·
Felülvizsgálat esedékes: 2027. május 19.

1. Dokumentum-információk

Mező	Érték
Adatkezelő	Petor Péter (egyéni szolgáltató)
Cím	2233 Ecser, Nádas Béla utca 10, Magyarország
Kapcsolat	hello@leakd.app
Adatvédelmi tisztviselő (DPO)	Nem kötelező kijelölni (lásd 1.1)
DPIA elkészítője	Petor Péter
Felügyeleti hatóság	Nemzeti Adatvédelmi és Információszabadság Hatóság (NAIH), Budapest, naih.hu
Érintett szolgáltatás	Leakd Felhő Szinkronizáció (Pro funkció)
Szolgáltatás indulása	2026 (Pro funkcióként)

1.1 DPO szükségességének vizsgálata (GDPR 37. cikk)

A DPO kijelölése **nem kötelező**, mert:

- nem közhatalmi feladat ellátása keretében történik az adatkezelés,
- a fő tevékenység **nem** olyan adatkezelés, amely az érintettek **rendszeres és szisztematikus, nagymértékű megfigyelését** igényli (a Cloud Sync végpontok közötti titkosított, az adatkezelő nem fér hozzá a tartalomhoz),
- nem végzünk **különleges kategóriájú** (9. cikk) vagy **bűnügyi** (10. cikk) adatok nagymértékű kezelését.

Kijelölés szakmai mérlegelés alapján: **nem szükséges**, de a NAIH bármikor írhat — a kapcsolattartó az adatkezelő maga.

2. Az adatkezelés rendszerszerű leírása (GDPR 35(7)(a))

2.1 Az adatkezelés célja

A Cloud Sync funkció lehetővé teszi a Leakd PWA Pro-előfizetésű felhasználói számára, hogy az appban tárolt **saját** előfizetési és beállítási adataikat a **saját Google Drive-jukban** biztonsági mentésként és több-eszközös szinkronizálási céllal tárolják, **végpontok közötti titkosítással**.

2.2 Az adatkezelés jogi alapja (GDPR 6. cikk)

A jogalap a **hozzájárulás** (6(1)(a) cikk).

- A felhasználó az appban kifejezetten bekapcsolja a Cloud Sync funkciót.
- Master jelszót ad meg, amelyet az adatkezelő **nem ismer és nem tárol**.
- A hozzájárulást a felhasználó bármikor visszavonhatja a funkció kikapcsolásával.

A Pro előfizetés mint **szerződés** (6(1)(b) cikk) jogalapja a Pro-funkciók nyújtására vonatkozik, **de a Cloud Sync bekapcsolása külön opt-in lépést igényel**.

2.3 Az érintettek köre

- A Leakd PWA Pro-előfizetésű felhasználói, akik **kifejezetten bekapcsolták** a Cloud Sync funkciót.
- Becsült létszám első évben: **<1 000 fő**. Skálázódás esetén a DPIA-t felül kell vizsgálni.

2.4 Kezelt személyes adatok kategóriái

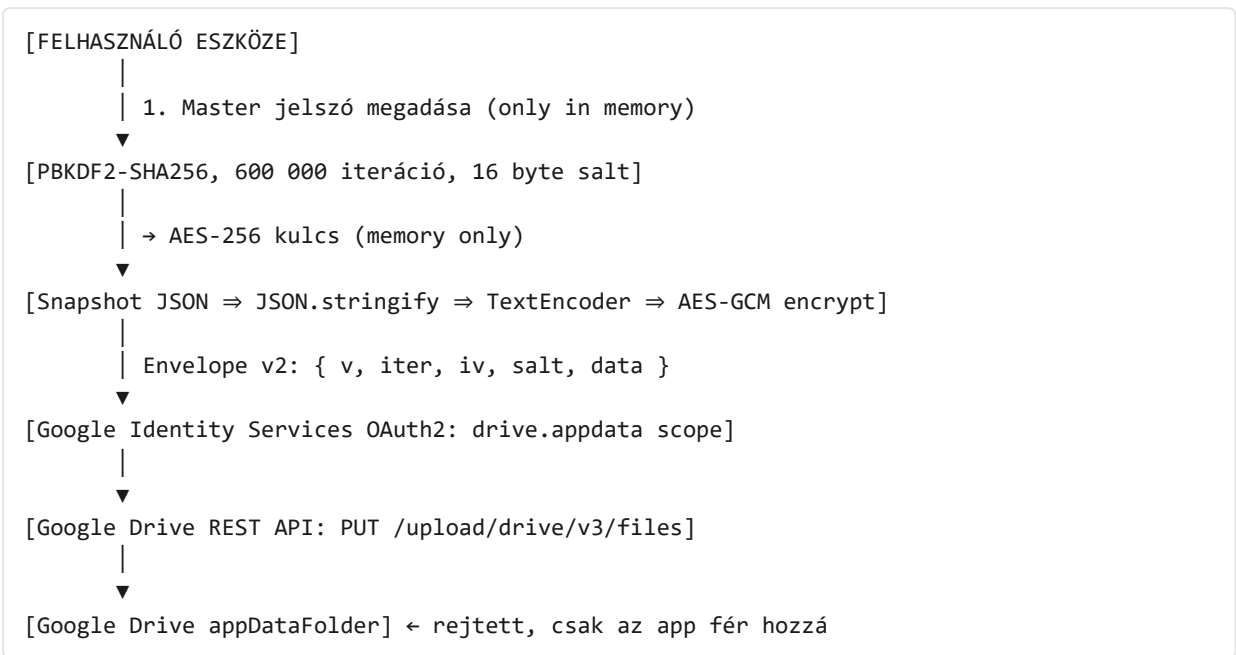
Adatkör	Típus	Megjegyzés
OAuth2 access token	Hitelesítési adat	Google szolgáltatja, in-memory tárolva, lejár (~1 óra)
Google Drive fájl-ID	Műszaki azonosító	<code>leakd_sync_meta</code> localStorage-ban
Master jelszó	Titok	Soha nem hagyja el az eszközt , csak in-memory
PBKDF2 salt	Kriptográfiai paraméter	16 byte random, <code>leakd_sync_salt</code> localStorage
Titkosított snapshot (ciphertext)	Származékos adat	AES-GCM 256-titkosított blob; a tartalmat sem az adatkezelő, sem a Google nem tudja olvasni
lastUpdated timestamp	Metaadat	Konfliktusfeloldás (last-write-wins)

A titkosított snapshot **dekódolva** (NEM kerül átadásra, csak a felhasználó eszközén) az alábbi kulcsokat tartalmazza:

- `leakd_subs` — előfizetés-lista
- `leakd_settings` — beállítások (nyelv, pénznem, téma)
- `leakd_cancelled` — lemondási nyilvántartás
- `leakd_budgets` — kategória költségvetések
- `leakd_goal` — megtakarítási cél
- `leakd_income` — opcionális jövedelem
- `leakd_history` — havi history snapshot
- `leakd_activity` — tevékenységnapló
- `leakd_notif_prefs` — értesítési preferenciák
- `leakd_lang` — nyelv
- `leakd_streak` — sorozat-adat
- `leakd_tour_done`, `leakd_onboarded` — onboarding állapot

Kifejezetten **NEM** kerül szinkronizálásra: `leakd_pro` (per-eszköz licenc), `leakd_rates` (pénznem cache), `leakd_sync_*` (szinkronizáció saját metaadatai), `leakd_notif_log` (eszközfüggő értesítés-napló).

2.5 Az adatkezelés folyamata



A folyamat **kizárólag a felhasználó eszközén és a saját Google fiókjában** zajlik. Az adatkezelő szervere nem érintett.

2.6 Címzettek (GDPR 35(7)(a))

Címzett	Szerep	Adat-elérés
Google LLC / Google Ireland Ltd	Adatfeldolgozó (Drive storage, OAuth)	Csak a titkosított blob-ot látja. A tartalmat nem tudja olvasni.
Adatkezelő (Péter Péter)	Adatkezelő	Soha nem fér hozzá a felhasználó adataihoz.
Harmadik fél	—	Nincs.

2.7 Adattovábbítás harmadik országba (44-49. cikk)

A Google Drive globális infrastruktúrát használ, beleértve az USA-t. A Google saját **Standard Szerződéses Klauszákkal** (SCC) és **EU-US Data Privacy Framework** csatlakozással rendelkezik. Mivel az adatkezelő által nyújtott adatok **végpontok közötti titkosításban** vannak, a transzfer kockázata minimális — a Google csak titkosított bájtokat lát.

2.8 Adatmegőrzési idő

Adatkör	Megőrzés
Titkosított blob a Google Drive-on	A felhasználó dönt — addig amíg a Cloud Sync-et használja, vagy törli.
OAuth token	Memóriában, lejáratí ideig (~1 óra), majd újra-kérés
Salt + fájl-ID localStorage-ban	A felhasználó eszközén, amíg a Cloud Sync engedélyezve van vagy a felhasználó nem törli az appot.
Master jelszó	Soha sem megőrizve. Lock vagy app-bezárás után törlődik a memóriából.

2.9 Technológiai függőségek

Komponens	Verzió/Specifikáció
Titkosítás	AES-GCM, 256-bit kulcs, 96-bit IV (random per snapshot)
Kulcs-derivátum	PBKDF2-SHA256, 600 000 iteráció (Envelope v2); legacy 250 000 (Envelope v1, csak olvasásra)
Salt	16 byte cryptographically-secure random
OAuth	Google Identity Services (GIS), <code>drive.appdata</code> scope
Tárolás	Google Drive <code>appDataFolder</code> (rejtett, csak az app fér hozzá)
Forráskód	<code>leakd/js/sync.js</code>

3. Az adatkezelés szükségességének és arányosságának értékelése (GDPR 35(7)(b))

3.1 Szükségesség

A funkció bevezetésének célja:

- **Felhasználói igény:** több eszközön történő használat (telefon + asztali).
- **Biztonsági mentés:** eszközvesztés vagy böngésző-adatok törlése esetén az előfizetés-történet helyreállítása.

Alternatívák értékelése:

Alternatíva	Előny	Hátrány	Választás
Manuális JSON export/import (jelenleg is létezik)	Egyszerű, nincs hálózati transzfer	Felhasználói súrlódás, könnyű elveszteni	Megmarad mint kiegészítő
Cloud Sync, E2EE, saját Drive	Auto-mentés, multi-device, az adatkezelő nem fér hozzá	Komplex, harmadik fél (Google) szükséges	Megvalósítva
Cloud Sync saját szerveren, kulcs nálunk	Egyszerűbb implementáció	Az adatkezelő látja az adatot — magasabb GDPR-kockázat	Elvetve
Cloud Sync E2E nélkül	Egyszerűbb	A Google látná az adatot — gyengébb védelem	Elvetve

3.2 Arányosság

- Csak **bekapcsolt funkció** esetén történik adatkezelés. **Alapértelmezetten kikapcsolt.**
- Csak a feltétlenül szükséges adatkulcsok kerülnek szinkronizálásra (lásd 2.4 kizárások).
- A titkosítás **az adatkezelő mértékére** veszi le a kockázatot: csak a felhasználó tudja visszafejteni.
- A hozzájárulás bármikor visszavonható (funkció kikapcsolása + Drive-fájl törlése).

Konklúzió: Az adatkezelés szükséges és arányos a felhasználói igény kielégítéséhez, és a legkisebb adatvédelmi kockázattal járó megoldást választottuk.

4. Az érintettek bevonása (GDPR 35(9))

Az érintettekkel folytatott konzultáció nem volt arányosan elvárható az alábbi okok miatt:

- A funkció **opt-in**: csak az használja, aki **kifejezetten kéri**.
- Az érintettek létszáma kicsi (<1 000).
- Az alkalmazott védelmi intézkedések (E2EE, PBKDF2 600 000 iteráció) az iparági legjobb gyakorlatot követik.

Mégis biztosítva van:

- A felhasználó az Adatvédelmi tájékoztatóban és a Felhasználási feltételekben **mind a 28 nyelven** olvashatja, mit mit küldünk és hova.
- A funkció **első bekapcsolásakor** részletes magyarázat jelenik meg az appban a master jelszóról.
- A hello@leakd.app címre érkező kérdésekre 30 napon belül válaszolunk.

Ha az érintettek létszáma túllépi a 10 000 főt, **NAIH-konzultáció vagy érintetti felmérés** is megfontolandó.

5. Kockázatértékelés (GDPR 35(7)(c))

5.1 Kockázati súlyozási rendszer

Súlyosság \ Valószínűség	Alacsony (1)	Közepes (2)	Magas (3)
Alacsony (1)	1 — minimális	2 — alacsony	3 — közepes
Közepes (2)	2 — alacsony	4 — közepes	6 — magas
Magas (3)	3 — közepes	6 — magas	9 — kritikus

5.2 Azonosított kockázatok

K1 — Master jelszó elvesztése a felhasználó által

- **Mi történne:** A felhasználó nem fér hozzá a Google Drive-on tárolt titkosított blob-hoz.
- **Súlyosság:** Közepes (2) — az adat a felhasználói eszközön továbbra is elérhető lokálisan.
- **Valószínűség:** Közepes (2) — felhasználók gyakran elfelejtik a master jelszót.
- **Kockázat:** 4 — közepes

K2 — A felhasználó Google fiókjának kompromittálása

- **Mi történne:** A támadó hozzáfér a titkosított blob-hoz, de **a master jelszó nélkül nem tudja visszafejteni.**
- **Súlyosság:** Alacsony (1) — E2EE miatt a támadó csak véletlen bájtokat lát.
- **Valószínűség:** Közepes (2) — Google fiók kompromittálás reális szcenárió.
- **Kockázat:** 2 — alacsony

K3 — Master jelszó kitalálása brute-force támadással

- **Mi történne:** A támadó hozzáfér a blob-hoz ÉS sikeresen kitalálja a jelszót.
- **Súlyosság:** Magas (3) — az összes szinkronizált adat felfedhető.
- **Valószínűség:** Alacsony (1) — PBKDF2 600 000 iteráció jelentősen drágítja a próbálkozást (~200ms iteráció per kísérlet modern GPU-n is). 8+ karakteres jelszó esetén több milliárd éves brute-force költség.
- **Kockázat:** 3 — közepes
- **Mitigáció:** Master jelszó minimum 4 karakter (kódban kényszerítve, `PASSWORD_TOO_SHORT` hibakód). Erősebb jelszót javasolunk az UI-ban (jövőbeli javítás).

K4 — Implementációs hiba az E2EE-ben

- **Mi történne:** Egy bug miatt a titkosítás megkerülhető, vagy a kulcs gyengébben származtatott.
- **Súlyosság:** Magas (3) — az összes szinkronizált adat felfedhető.
- **Valószínűség:** Alacsony (1) — Web Crypto API natív primitív; a PBKDF2/AES-GCM iparági szabvány; a kódot átnéztük, dokumentáltuk, tesztekkel fedjük.
- **Kockázat:** 3 — közepes
- **Mitigáció:** Test suite `test_sync.cjs` ellenőrzi az E2EE round-tripet és a „no plaintext leakage”-et. Új `test_sync_v2_migration.cjs` ellenőrzi a v1→v2 migrációt és a key-derivation helyességét. Forráskód nyilvános auditra elérhető.

K5 — Adatkezelő-oldali adatszivárgás

- **Mi történe:** A leakd.app szerver-oldali kompromittálódik.
- **Súlyosság:** Alacsony (1) — **az adatkezelő szervere nem érintett a Cloud Sync-ben.** Nincs szerverünk amelyen a felhasználói adatok tárolódnának.
- **Valószínűség:** Alacsony (1).
- **Kockázat: 1 — minimális**

K6 — Google szolgáltatás kompromittálódása

- **Mi történe:** A Google Drive infrastruktúrája támadás célpontja lesz.
- **Súlyosság:** Alacsony (1) — E2EE miatt csak titkosított bájtok láthatók.
- **Valószínűség:** Alacsony (1) — Google biztonsági fellépésével és reagálási képességével.
- **Kockázat: 1 — minimális**

K7 — Felhasználói hozzájárulás visszavonásának nem teljesítése

- **Mi történe:** A felhasználó kikapcsolja a Cloud Sync-et, de az adat a Drive-on marad.
- **Súlyosság:** Közepes (2) — GDPR megsértés (törléshez való jog).
- **Valószínűség:** Közepes (2) — Az aktuális UI nem törli automatikusan a Drive-fájlt kikapcsoláskor.
- **Kockázat: 4 — közepes**
- **Mitigáció:** Az Adatvédelmi tájékoztató §17.2 részletesen leírja a fájl manuális törlésének lépéseit.
Jövőbeli javítás: A Cloud Sync kikapcsoláskor automatikusan ajánljuk fel a Drive-fájl törlését (`files.delete` API-hívással).

K8 — Régi (v1, 250k iteráció) snapshot támadhatósága

- **Mi történe:** Az új v2 (600k) bevezetése előtt mentett blob-ok elméletileg könnyebb támadási célpontok.
- **Súlyosság:** Közepes (2).
- **Valószínűség:** Alacsony (1) — 250k iteráció is iparági standard volt 2024 előtt; nem ismert tömeges brute-force.
- **Kockázat: 2 — alacsony**
- **Mitigáció:** A v1 blob a **legközelebbi push-kor automatikusan átíródik v2-re.** Migrációt ellenőrzött teszt (`test_sync_v2_migration.cjs`) bizonyítja.

5.3 Kockázati összefoglaló

Kockázat	Pontszám	Státusz
K1 — Master jelszó elvesztés	4	Elfogadható + mitigáció
K2 — Google fiók kompromittálás	2	Elfogadható
K3 — Brute-force támadás	3	Elfogadható + mitigáció
K4 — Implementációs hiba	3	Elfogadható + mitigáció
K5 — Saját szerver kompromittálása	1	Nem releváns
K6 — Google kompromittálódás	1	Elfogadható
K7 — Hozzájárulás visszavonás	4	Elfogadható + javítási terv
K8 — Régi blob	2	Elfogadható + auto-migráció

Maximális azonosított kockázat: 4 (közepes). Egyetlen kockázat sem éri el a magas (6+) vagy kritikus (9) szintet. **NAIH-konzultáció a 36. cikk alapján nem szükséges.**

6. Tervezett intézkedések (GDPR 35(7)(d))

6.1 Megvalósított technikai intézkedések

Intézkedés	Hely a kódban
AES-GCM 256 titkosítás	<code>sync.js:185-193</code> (<code>encryptWithKey</code>)
PBKDF2-SHA256 600 000 iteráció	<code>sync.js:43, 122-134</code> (<code>deriveKey</code>)
16-byte cryptographic random salt	<code>sync.js:113-119</code> (<code>getSalt</code>)
96-bit random IV per snapshot	<code>sync.js:186</code>
Master jelszó nem perzisztálódik	<code>sync.js:65, 139, 170-173</code>
Envelope versioning + iter mező	<code>sync.js:43-45, 187-193</code>
Pro-gate (jogosulatlan hozzáférés-tiltás)	<code>sync.js:102-110</code> (<code>checkPro</code>)
OAuth <code>drive.appdata</code> scope (legkisebb jog)	<code>sync.js:36</code>
OAuth token in-memory only	<code>sync.js:66-68</code>

6.2 Megvalósított szervezési intézkedések

Intézkedés	Hivatkozás
Adatvédelmi tájékoztató (GDPR 13. cikk)	<code>leakd/privacy.html</code> — 28 nyelv
Felhasználási feltételek + ÁSZF	<code>leakd/terms.html</code> — 28 nyelv
Kifejezett ÁSZF-elfogadás onboarding-on	<code>app.js:3197-3221</code> + <code>index.html:1566-1581</code>
Adattörlés folyamata dokumentálva	<code>privacy.html</code> §17
Visszatérítési szabályzat	<code>terms.html</code> §25
Tesztuite	<code>test_sync.cjs</code> , <code>test_sync_v2_migration.cjs</code> — 16/16 PASS

6.3 Tervezett (folyamatban lévő) intézkedések

Intézkedés	Határidő	Felelős
Cloud Sync kikapcsoláskor automatikus Drive-fájl törlési ajánlat	Q3 2026	Petor Péter
Erős master jelszó-javallat (entrópia-mérő)	Q3 2026	Petor Péter
NAIH adatkezelési nyilvántartás regisztráció	2026 július	Petor Péter
Felelősségbiztosítás (cyber + szakmai) megkötése	2026 július	Petor Péter
DPIA felülvizsgálat	2027 május	Petor Péter
Incidentsreagálási terv (IRP) formalizálása	Q4 2026	Petor Péter

6.4 Incidenskezelés (GDPR 33-34. cikk)

72 órás bejelentési kötelezettség: Ha adatvédelmi incidens történik (pl. a kódban olyan hiba derül ki, amely lehetővé teszi a titkosított blob visszafejtését), az adatkezelő:

- 0-1 óra:** Az incidens azonosítása, érintettek és súlyosság megállapítása.
- 1-24 óra:** Mitigáció (pl. új verzió release-elése, érintett fájlok kényszerített újratitkosítása).
- 24-72 óra:** NAIH bejelentés a naih.hu-n keresztül.
- Magas kockázat esetén:** Az érintett felhasználók közvetlen értesítése (in-app banner + email a Pro-felhasználóknak).

7. Jóváhagyás

Ezen DPIA-t az adatkezelő áttekintette és jóváhagyta.

Szerep	Név	Aláírás	Dátum
Adatkezelő	Petor Péter		2026-05-19
Adatvédelmi tisztviselő	— (nem kötelező)	—	—

8. Verziókezelés

Verzió	Dátum	Változás	Felelős
1.0	2026-05-19	Kezdeti dokumentum, Cloud Sync v2 indulásra	Petor Péter

Következő kötelező felülvizsgálat: 2027-05-19, **vagy** korábban ha:

- a felhasználói létszám meghaladja a 10 000 főt,
- új adatkör kerül szinkronizálásra,
- a titkosítási paramétereket módosítjuk,
- adatvédelmi incidens történik,
- az érintett jogszabályok módosulnak.

9. Hivatkozott dokumentumok

1. **GDPR (EU) 2016/679** — különösen 6, 7, 13, 17, 33, 34, 35, 36, 37. cikkek
2. **NAIH 2018/52. ajánlása** a DPIA-ról
3. **EDPB Guidelines 4/2019** on Article 25 — Data Protection by Design and by Default
4. **WP248 rev.01** — Guidelines on Data Protection Impact Assessment (DPIA)
5. **Leakd Privacy Policy** — `leakd/privacy.html`
6. **Leakd Terms of Service** — `leakd/terms.html`
7. **Leakd Sync Source Code** — `leakd/js/sync.js`
8. **Leakd Sync Test Suite** — `test_sync.cjs`, `test_sync_v2_migration.cjs`

Készült a GDPR 35. cikkének megfelelően. A dokumentum bizalmas, csak az adatkezelő, a megbízott jogi tanácsadó és a NAIH számára áll rendelkezésre kérésre.